



FedRAMP 20x Community Update

August 12, 2026





[REC ●]

FedRAMP Community Discussions on GitHub:

<https://github.com/FedRAMP/community/discussions>

FedRAMP Video Recordings on YouTube:

<https://www.youtube.com/@FedRAMP/videos>

Legal Disclaimer

I am communicating today in my official capacity on behalf of FedRAMP at the General Services Administration.

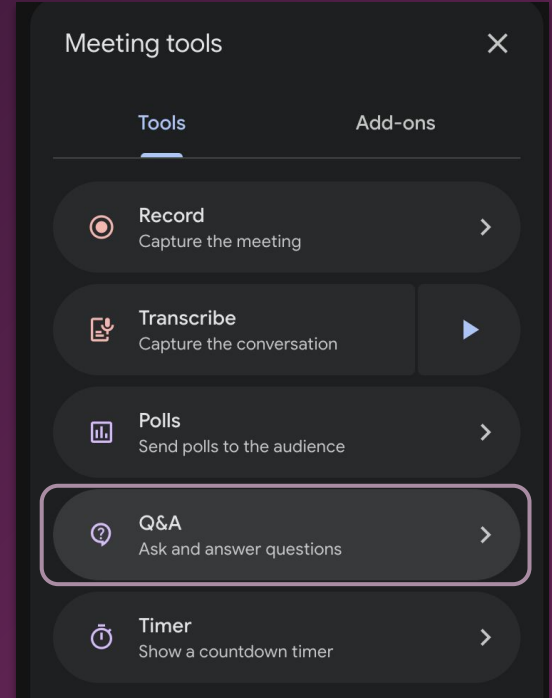
We hold these meetings to enhance transparency between industry and FedRAMP so that we can open a dialogue and share new developments.

Nothing that we share constitutes business advice, and any reference in this conversation to any specific commercial product or the use of any corporation name is for the information and convenience of the public, and does not constitute endorsement, recommendation, or favoring by GSA.

General Q&A

During the meeting, use the Q&A feature in Google Meet to ask questions.

We will try to answer relevant questions as they are asked and have a dedicated Q&A at the end of the meeting.



AGENDA

01

FEDRAMP SUPPORT

02

USING AI TO HELP UNDERSTAND THE RULES

03

CLASS A - OPEN NOW!

04

CLASS B & C - SOON...

05

REQUEST FOR COMMENT

05

Q&A

FedRAMP Support

01

Communicating with FedRAMP

Questions or feedback on FedRAMP process, rules, timeframes, etc

- Community: <https://github.com/FedRAMP/community/discussions>
- CR26 specific, ask at bottom of page: <https://www.fedramp.gov/2026/>

Agency support, specific and sensitive discussions

- FedRAMP help desk: info@fedramp.gov

Currently expanding <https://help.fedramp.gov/> to include forms & help articles

Using AI for CR26

02

Machine Readable Rules

Machine readable content:

<https://github.com/FedRAMP/2026-markdown>

Machine readable rules:

<https://github.com/FedRAMP/rules>

 README

FedRAMP 2026 Markdown Content

This repository contains pure Markdown content for the FedRAMP Consolidated Rules for 2026.

The content is generated from two upstream sources:

- Structured rule data from `fedramp-consolidated-rules.json` in the FedRAMP Rules repository.
- Hand-written narrative content from the FedRAMP 2026 repository.

Together, these files are the underlying Markdown corpus that is rendered into HTML using Zensical.

The purpose of this repository is to expose the Markdown directly to AI agents and other text-oriented tools so they can work from the source content without crawling the rendered HTML site.

Source commit metadata is recorded in `_sources.json`.

FedRAMP Consolidated Rules

This repository contains the machine-readable FedRAMP Consolidated Rules for the 2026 Public Preview.

The source of truth is:

- [fedramp-consolidated-rules.json](#)
- [schemas/fedramp-consolidated-rules.schema.json](#)

Everything else in this repository supports those two files.

What Is Here

- [fedramp-consolidated-rules.json](#) The canonical rules dataset.
- [schemas/fedramp-consolidated-rules.schema.json](#) The schema for the dataset.
- [AGENTS.md](#) Guidance for AI agents analyzing the dataset.
- [tools](#) Validation, normalization, tests, and export tooling.

Working With The Repository

Use the `JSON` file and schema for analysis.

MCP Server Proof of Concept

<https://github.com/dan-fedramp/fedramp-rules-mcp>

FedRAMP Rules MCP Server

An [MCP](#) server that answers questions about the **FedRAMP Consolidated Rules for 2026**. It bundles the official markdown corpus from [fedramp/2026-markdown](#) and exposes it to LLM agents through search and retrieval tools, so answers come from the authoritative source text — with citations to file paths and rule IDs.

The content is **vendored at a pinned commit** (see `scripts/sync_content.py`), so the server works offline, responds instantly, and gives stable, reproducible answers. Re-run the sync script to update.

Tools

Tool	Description
<code>fedramp_search</code>	BM25 full-text search across the whole corpus. Optional <code>section</code> prefix filter; returns ranked snippets with paths. Identical-content hits (the <code>reference/</code> <code>a/b/c/d</code> tracks) are merged.
<code>fedramp_get_document</code>	Return the full markdown of one document by its repo-relative <code>path</code> .
<code>fedramp_list_documents</code>	Browse the corpus tree, optionally filtered to a section.
<code>fedramp_get_rule</code>	Retrieve a rule by ID (<code>FRC-CS0-FCP</code> , <code>VDR-CS0-CVE</code> , <code>KSI-IAM-01</code> , ...) or a NIST control ID (<code>AC-20</code> , <code>SI-4</code>), with every location it appears. Case-insensitive.
<code>fedramp_get_definition</code>	Look up a defined term by name, alias, or FRD ID (<code>FRD-SGC</code>). Case-insensitive.

There is also a `fedramp://source` resource exposing the source repo, pinned commit, and sync timestamp for provenance.

- Simple MCP server that can be integrated into any AI client
- Makes the Consolidated Rules available to AI agents with some common functions
- Proof of concept. Not an official FedRAMP product provided without warranty and with no expectation of ongoing development or maintenance.

AI as a blunt tool for Machine Readable

Prompt: **JSON**

You are a cybersecurity analyst working at the GSA. Your job is to determine risks to agency information when using a FedRAMP authorized cloud service. The FedRAMP Consolidated Rules for 2026 can be found at <https://github.com/fedramp/2026-markdown>. Analyse the security decision record at <https://csp.com/sdr.json> and generate a human readable report containing all the information in the SDR and highlight any potential risks to the agency data

Security Decision Record — Analysis Report

- Cloud Service: MeridianOps Cloud Platform (MOCP)
- FedRAMP ID: FR2026-MOCP-001
- Vendor: Meridian (meridianfed.com)
- Trust Center: <https://trust.meridianfed.com/mocp>
- Certification Package Overview: <https://meridianfed.com/fedramp/mocp/certification-package-overview.json>
- Report prepared: 2026-08-11 (analyst working copy)

1. Service Overview

MOCP is a multi-tenant SaaS platform that appears to process federal grant data (references to a "grants-api" service, "grant-data file transfers," and "CUI" data access). The record indicates the service handles **Controlled Unclassified Information (CUI)** and ingests bulk grant data from agency legacy systems.

2. Ports, Protocols & Services

Service	Port	Transport	Encryption	Purpose
Web Application (HTTPS)	443	TCP	TLS 1.3	Tenant/admin web access to MOCP
PostgreSQL Replica Sync	5432	TCP	TLS 1.2	Internal VPC-only DB replication (primary → read-replica)
SFTP Batch Ingest	22	TCP	SSH	Nightly bulk grant-data transfers from agency legacy systems; restricted to allowlisted agency egress IPs

3. Security Controls (NIST 800-53)

Security Decision Record — Analysis Report

- **Cloud Service:** MeridianOps Cloud Platform (MOCP)
- **FedRAMP ID:** FR2026-MOCP-001
- **Vendor:** Meridian (meridianfed.com)
- **Trust Center:** <https://trust.meridianfed.com/mocp>
- **Certification Package Overview:** <https://meridianfed.com/fedramp/mocp/certification-package-overview.json>
- **Report prepared:** 2026-08-11 (analyst working copy)

1. Service Overview

MOCP is a multi-tenant SaaS platform that appears to process federal grant data (references to a "grants-api" service, "grant-data file transfers," and "CUI" data access). The record indicates the service handles **Controlled Unclassified Information (CUI)** and ingests bulk grant data from agency legacy systems.

2. Ports, Protocols & Services

Service	Port	Transport	Encryption	Purpose
Web Application (HTTPS)	443	TCP	TLS 1.3	Tenant/admin web access to MOCP
PostgreSQL Replica Sync	5432	TCP	TLS 1.2	Internal VPC-only DB replication (primary → read-replica)
SFTP Batch Ingest	22	TCP	SSH	Nightly bulk grant-data transfers from agency legacy systems; restricted to allowlisted agency egress IPs

3. Security Controls (NIST 800-53)

Control	Status	Summary
AC-02 (Account Mgmt)	Implemented	Automated provisioning/deprovisioning via Okta + SCIM; disabled accounts removed within 1 hour
AC-06 (Least Privilege)	Implemented	RBAC; privileged access is just-in-time with 8-hour expiry
AU-02 (Audit Events)	Implemented	Auth events, admin actions, CUI access logged to SIEM; 1-yr hot / 3-yr cold retention
IA-02 (Identification & Auth)	Implemented	Phishing-resistant MFA (FIDO2/WebAuthn); password-only auth disabled
SC-07 (Boundary Protection)	Implemented	AWS security groups + NACLs, default-deny inbound; WAF on inbound HTTPS
SC-13 (Cryptographic Protection)	Implemented	AES-256 at rest (AWS KMS); TLS 1.2+ in transit
CM-06 (Config Settings)	Partially Implemented	Terraform + CI/CD baselines; legacy batch hosts not yet migrated (target Q4 2026)
RA-05 (Vuln Scanning)	Implemented	Weekly authenticated scans; findings tracked per internal SLAs
CP-09 (System Backup)	Implemented	Daily snapshots, 35-day retention, cross-region; quarterly restore tests
SI-04 (System Monitoring)	Implemented	Managed SIEM/SOAR, 24/7 SOC rotation

Note: A parameter mismatch exists in AC-02 (see Risk Analysis).

4. FedRAMP Requirements (FRRs)

FRR ID	Status	Summary
SDR-CSO-MTD	Implemented	SDR published/versioned with metadata; validated against FedRAMP schemas in CI; assessor-confirmed
CDS-CSO-PUB	Implemented	Public info published without auth; quarterly URL reachability audit
CDS-CSO-FID	Implemented	FedRAMP ID published in overview, Trust Center, Marketplace
CDS-CSO-UTC	Implemented	Self-service Trust Center; agency access logged/reviewed monthly
AFC-CSO-INB	Implemented	Monitored security inbox; 1-business-day acknowledgment; tested quarterly
SCN-CSO-EVA	Implemented	Changes evaluated against Adaptive/Transformative criteria at weekly CAB
VER-RPT-VDT	Implemented	Monthly Vulnerability Detail Reports published to Trust Center
VER-RPT-AVI	Implemented	Accepted vulnerabilities tracked with rationale, reported monthly
VER-RPT-PER	Implemented	Persistent monthly reporting cadence, no gaps
CCM-OCR-AVL	Implemented	Ongoing Certification Reports published quarterly within 5 business days
IEC-CSO-EFR	Implemented	Incidents evaluated for reportability within 4 hours of triage
MAS-CSO-IIR	Implemented	Minimum Assessment Scope resources inventoried, tagged by data flow/category
CMU-CSO-CMD	Implemented	Crypto modules (AWS KMS, OpenSSL 3.x FIPS) documented with cert references
SDR-CSX-KSI	Implemented	KSIs for the certification class documented (see below)

5. Key Security Indicators (KSIs)

KSI ID	Status	Summary	Independent Assessment?
KSI-CED-RAT	Implemented	Annual security awareness training; quarterly reconciliation	Yes — 15 records, 100%
KSI-CMT-LMC	Implemented	Changes logged via CI/CD + CloudTrail; weekly reconciliation	Yes — 20 deployments, no discrepancy
KSI-CMT-VTD	Implemented	Automated smoke/integration tests, blue/green deploy	No assessment statement
KSI-CNA-MAT	Implemented	Minimal container base images; quarterly attack-surface review	Yes — sample reviewed
KSI-CNA-RNT	Implemented	mTLS service mesh, allow-listed service paths; monthly flow-log review	No assessment statement
KSI-IAM-ELP	Implemented	Least-privilege IAM roles; no standing admin; quarterly reviews	Yes — 25 accounts sampled
KSI-IAM-JIT	Implemented	JIT admin via PAM, 8-hour expiry; weekly session review	No assessment statement
KSI-INR-RIR	Implemented	IR plan reviewed annually + post-incident; version controlled	No assessment statement
KSI-MLA-OSM	Implemented	Managed SIEM, 24/7 correlation; weekly source-health review	Yes — all sources confirmed
KSI-MLA-RVL	Implemented	Daily log review via dashboards; anomaly-triggered deep dives	No assessment statement
KSI-PIY-GIV	Implemented	Continuous asset discovery; weekly boundary reconciliation	No assessment statement
KSI-RPL-ABO	Implemented	Backups aligned to 24-hr RPO; nightly verification	Yes — config confirmed
KSI-SCR-MON	Partially Implemented	SCA on direct deps; transitive/third-party deps in progress (Q3 2026)	No assessment statement
KSI-SVC-ASM	Implemented	Secrets in AWS Secrets Manager, 90-day rotation; commit scanning	Yes — full repo scan clean
KSI-SVC-SIN	Implemented	Per-tenant schema + row-level security + tenant KMS grants	Yes — pentest confirmed isolation

6. Risk Analysis — Potential Risks to Agency Data

I've grouped findings by severity. Severity ratings are my analytical judgment based on the document contents and general FedRAMP framework concepts — **they are not official risk determinations.**

Higher-Priority Items

R-1. AC-02 parameter mismatch (deprovisioning timeframe inconsistency) The AC-02 narrative states disabled accounts are removed "within 1 hour," but the associated parameter value (`ac-02_prm_1`) is set to "24 hours." This is a direct contradiction between the implementation statement and the assigned control parameter. This matters because it creates ambiguity about the *committed* SLA. If the enforceable commitment is 24 hours, there is a window in which a terminated/compromised account could retain access to agency CUI. **Recommend clarifying which value is authoritative and confirming the actual technical enforcement.**

R-2. Supply-chain monitoring gap (KSI-SCR-MON — Partially Implemented) Transitive and third-party service dependencies are **not yet continuously monitored** for vulnerabilities (target Q3 2026, which by today's date of Aug 11, 2026 may be near or past due). Supply-chain compromise via an unmonitored transitive dependency is a realistic path to agency data exposure. **Recommend confirming current completion status against the Q3 2026 target — this deadline may now be overdue.**

R-3. Legacy batch-processing hosts outside config baseline (CM-06 — Partially Implemented) A subset of legacy batch-processing hosts are **not yet under the Terraform/CI-CD configuration management pipeline** (target Q4 2026). Notably, these are the hosts most likely involved in the **SFTP grant-data ingest** — i.e., the exact path your agency's bulk grant data flows through. Unmanaged configurations on data-ingest hosts represent configuration drift and hardening risk directly adjacent to agency data. **Recommend understanding whether these legacy hosts touch agency data before ingest is fully secured.**

Moderate-Priority Items

R-4. Accepted vulnerabilities in a data-path component (KSI-CNA-MAT) The grants-api container image shows "2 MEDIUM (accepted)" vulnerabilities. Acceptance is a legitimate risk decision, but the **acceptance rationale is not shown** in this record. Since grants-api appears to be a primary data-handling component, the agency should review the documented rationale (reported per VER-RPT-AVI) rather than relying on acceptance alone.

R-5. TLS 1.2 on the database replication path (PostgreSQL / SC-13) Replica sync uses TLS 1.2 while the web tier uses TLS 1.3. TLS 1.2 remains FedRAMP-acceptable and this is VPC-internal traffic, so residual risk is low — but it is the weakest crypto in the stack and worth noting as a hardening opportunity.

R-6. FIPS 140 validation not explicitly confirmed CMU-CSO-CMD references AWS KMS and "OpenSSL 3.x FIPS module" with "validation certificate references in the system security documentation," but the **actual CMVP certificate numbers and validation status are not in this record.** For CUI, FIPS 140-validated (not merely "FIPS-capable") modules are typically required. **Recommend verifying the specific CMVP certificates in the referenced documentation.**

Lower-Priority / Assurance Observations

R-7. Several KSIs lack independent assessor statements. KSI-CMT-VTD, KSI-CNA-RNT, KSI-IAM-JIT, KSI-INR-RIR, KSI-MLA-RVL, KSI-PIY-GIV, and KSI-SCR-MON have **empty ksiAssessment** fields. These rely on vendor self-attestation with no documented independent validation. This is common and not necessarily a deficiency, but the assurance level is lower for these controls

Class A Open

03

Class A is Open for Submission!

Approved Alternative Framework materials + selection of CR26 Rules & KSIs

1 GET LISTED

- Valid audit/assessment
- Create Certification Package Overview (CPO)
- Submit Marketplace request form

2 DO THE WORK

- Get a FR-compatible Trust Center
- Adopt/adapt policy to meet rules
- Create Certification package
- (Optional) Independent Verification & Validation

3 GET CERTIFIED

- Submit Certification request form
- Support Program review
- Congrats! Certified
- Ongoing Certification responsibilities

Class A Submission Package

- External Assessment Materials
 - Certification Package Overview (CPO)
 - Security Decision Record (SDR)
 - Sample schemas (referenced by applicable rules)
 - Initial Incident Report (IEC-CSO-IIR) **SHOULD**
 - Ongoing Incident Report (IEC-CSO-OIR) **SHOULD**
 - Final Incident Report (IEC-CSO-FIR) **MUST**
 - Historical VER Activity (VER-TFR-MRH) **MAY** - *if Rule is included in SDR*
 - Ongoing Certification Report (CCM-OCR-AVL) **MUST**
 - Assessment Summary (in SDR) and Overall Summary of Assessment (CPO) - *if optional IV&V*
-

Tips for a Smooth Process

Completeness

- Human and machine-readable files present
- ALL MUST and SHOULD rules included in SDR (even if not met)
- MAY are extra credit, but if included will be FULLY reviewed

Accuracy

- Use the JSON Schema Validator: <https://www.fedramp.gov/schemas/validator/>
- If a rule/KSI is not fully implemented, mark as Partially Implemented - please and thanks

Review Experience

- Easy to access and use Trust Center
- Simple to find artifacts (direct links from SDR best!)

Class A FAQs

Q. Can I do a Class A for Rev5?

- A. No. Only 20x, but you can progress to either Rev5 or 20x Certification.

Q. Does Class A support hybrid or self-hosted infrastructure?

- A. Yes. Class A is open to all deployment types.

Q. I have a different framework than what was listed, can I use it?

- A. No. Only SOC 2 Type II, GovRAMP, and FedRAMP Ready are approved alternative frameworks in CR26. Additional frameworks may be added for CR27.

Q. I don't have an assessment from any of the approved frameworks, can a FedRAMP recognized Independent Assessment Organization do an assessment instead?

- A. No. Class A is intended to be low lift, bring your own framework. Do a Class B or C instead.

Class A FAQs cont.

Q. Can an agency use a Class A Certification?

- A. Yes a Class A Certification is a **REAL** FedRAMP Certification. They will be used for limited, very low risk, evaluation type of use cases, but this better supports a “Try then Buy” procurement strategy.

Q. How long does it take to get a Class A Certification?

- A. It is designed to be fairly low lift. Our SLA for ALL FedRAMP Certification reviews is 30 business days from acceptance (less any time we are waiting for CSP action). Once we have a decent sample size, we will start releasing average actual times.

Class B & C

04

Class B & C Open Soon

July 6, 2026

Marketplace initial implementation
listing open

**August 31,
2026**

Class B & C pipelines open

20x Pilot Certification Conversion

The 12 month window is no longer applicable. Follow CR26 **Maintain** timelines.

Quarterly Check-in

- Can be at your CCM Quarterly meeting!
- Send invite to Info@fedramp.gov

CR26 Adoption

- Persistently show progress
- Follow Maintain dates
- Class B or Class C

Final Submission

- Submit final certification package
- Can be as an annual review or new if changing class

Failure to show progress or meet CR26 Maintain / Grace period dates will result in revocation of pilot certification and delisting from the FedRAMP Marketplace.

Certification Process

1 GET LISTED

- Create Certification Package Overview (CPO)
- Submit Marketplace request form

2 DO THE WORK

- Get a FR-compatible Trust Center
- Adopt/adapt policy to meet rules
- Create Certification package
- Independent Verification & Validation
- Automation & Historical Metrics (MUST Class C, SHOULD Class B)

3 GET CERTIFIED

- Submit Certification request form
- Support Program review
- Congrats! Certified
- Ongoing Certification responsibilities

Class B & C Program Review Process

1 INTAKE

Completeness check
Added to Queue
Marketplace Update

2 KICKOFF

Team Assignment
Trust Center Access
Walkthrough

3 INTERNAL REVIEW

Team performs
internal review

4 COLLAB REVIEW

Review team meets
with Provider and
Assessor

5 DETERMINATION

Certification Report
Final Disposition

6 CERTIFIED

Congrats! Certified
Certification Letter

Tips for a Smooth Process

Completeness

- Human and machine-readable files present
- ALL MUST and SHOULD rules included in SDR (even if not met)
- MAY are extra credit, but if included will be FULLY reviewed

Accuracy

- Use the JSON Schema Validator: <https://www.fedramp.gov/schemas/validator/>
- If a rule/KSI is not fully implemented, mark as Partially Implemented - please and thanks

Review Experience

- Easy to access and use Trust Center
- Simple to find artifacts (direct links from SDR best!)

Tips for a Smooth Process Cont.

Readability

- The implementation description should clearly and concisely describe what is in place and any future plans to address any gaps with specific timeframes
- Verification, Validation, Tests, Evidence, etc should be clearly described
- Think who, what, when, where, why, and how

Relevance

- Don't provide a “turducken” of artifacts, ensure each test and piece of evidence is relevant to the specific rule or KSI. Too much info can be a bad thing if it doesn't make sense
- Metrics should directly relate to the outcome, a pretty graph with little context is not helpful

Force of the Rule

MUST	The rule is an absolute requirement. Parties MUST meet such rules and address them in their security documentation. Failure to follow the rule is a vulnerability that may lead to corrective action and the denial of initial or ongoing FedRAMP Certification.
MUST NOT	The rule is an absolute prohibition. Parties MUST meet such rules and address them in their security documentation. Failure to follow the rule is a vulnerability that may lead to corrective action and the denial of initial or ongoing FedRAMP Certification.
SHOULD	There may exist valid reasons in particular circumstances to ignore this rule, but the full implications must be understood and carefully weighed. Parties MUST address such rules in their security documentation by explaining their decisions about how they handle such rules.
SHOULD NOT	There may exist valid reasons in particular circumstances when the particular action is acceptable or even useful, but the full implications must be understand and carefully weighed. Parties MUST address such rules in their security documentation by explaining their decisions about how they handle such rules.
MAY	The rule is truly optional. Parties SHOULD address such rules in their security documentation by explaining their decisions about how they handle such rules.

Request for Comment

05

RFC-0032 Offerings By Government

Open **August 6th - September 8th**

FedRAMP will establish an Offerings by Government Ruleset:

- Exempt agency cloud service providers from FedRAMP Rules except those in the Offerings By Government ruleset
- Ruleset deviation is subject to Agency approval
- Agency CSPs MUST have an ATO (no program certification paths)
- Agencies must provide their own trust centers

RFC-003x Li-SaaS Retirement

Open soon: **Aug/Sep 2026**

No more Li-SaaS after 01/01/2027

2 types of replacement, 20x vs Rev5:

- Switch to Rev5 Class B - June 11, 2027

-OR-

- Switch to 20x Class B - September 30, 2027

RFC-003x 20x Phase 4 Pilot

Open soon: **Aug/Sep 2026**

Phase 4 will focus on 20x Class D certifications (including self-hosted infrastructure)

Expected Pilot will run October 2026 - March 2027

Target participants will be announced later

Q&A

06



Close-Out